

OWASP Juice Shop — Penetration Test Report

Synthetic evaluation fixture (lab data only)

Finding 1 — SQL Injection in Login Form

Attribute	Value
Severity	Critical
CWE	CWE-89
CVSS	9.8
Affected endpoint	POST /rest/user/login

Description: The login endpoint concatenates the submitted email directly into a SQL query. A crafted email bypasses authentication and returns a valid session for the first matching account.

Steps to reproduce:

1. Browse to the login page at /#/login.
2. Enter the email ' **OR 1=1--** and any password.
3. Observe a successful login as the administrator account.

Finding 2 — Reflected Cross-Site Scripting in Search

Severity: High

Affected endpoint: GET /#/search?q=

Description: The product search reflects the q parameter into the page without encoding, executing attacker-supplied markup in the victim's browser.

Steps to reproduce:

1. Submit the search term <iframe src=javascript:alert(1)>.
2. Observe the injected iframe executing on the results page.

Finding 3 — Broken Access Control on Basket

Severity: High

Affected endpoint: GET /rest/basket/{id}

Description: Basket identifiers are sequential and not tied to the authenticated user, so any basket can be read by changing the id.

Steps to reproduce:

1. Log in and note your own basket id at /rest/basket/1.
2. Request /rest/basket/2 and read another user's basket.

Finding 4 — Verbose Error Messages Expose Stack Traces

Severity: Medium

Affected endpoint: GET /rest/products/search

Description: Malformed requests return an unhandled exception including the SQL statement and server file paths, aiding further attacks.

Steps to reproduce:

1. Send GET /rest/products/search?q='') to the API.
2. Observe the full stack trace in the JSON response.